

Guardivex Phase 1 Architecture Summary

Safety rule: AI must never directly control doors, panels, alarms, relays, or switch ports.

AI may only recommend actions or draft command requests. Commands must pass RBAC, rules evaluation, approval workflow, audit logging, and the command execution service.

Implemented structure:

- apps/web: Vite React TypeScript frontend for Cloudflare Pages.
- apps/api: Fastify TypeScript API for Hetzner VPS.
- packages/shared: Zod schemas and shared security contracts.
- packages/database: Prisma schema/client for Postgres.

Backend foundation:

- Fastify with Helmet, CORS, rate limiting, JWT auth, Zod validation, and central errors.
- Argon2 password verification and opaque refresh session storage.
- RBAC middleware rehydrates permissions from Postgres after JWT verification.
- Tenant-scoped users, sites, devices, events, alerts, incidents, commands, and audit routes.

Database foundation:

- Postgres + Prisma for tenants, users, roles, permissions, sessions, sites, doors, devices, events, alerts, incidents, audit logs, command requests, approvals, and executions.
- Seed script creates the first tenant, owner role, full permissions, and hashed admin password.

Command safety:

- Command requests are policy-reviewed and require approval.
- Approvals are recorded separately from requests.
- Phase 1 uses a safe-null executor and does not send live hardware commands.

Infrastructure:

- docker-compose.yml for Postgres and API.
- Dockerfiles for API and optional web image.
- .env.example for local/staging/production environment structure.
- GitHub Actions CI plus Cloudflare Pages/API image workflows.

Validation:

- npm install completed.
- npm run build completed for shared, database, API, and web.
- Frontend runs from apps/web at <http://127.0.0.1:5000/>.

Next critical steps:

- Run migrations and seed the first tenant/admin.
- Move refresh tokens to HttpOnly secure cookies before production.
- Add tests for auth, tenant isolation, RBAC denial, audit creation, and command approvals.
- Build command request and audit log UI screens.
- Add read-only hardware adapters before any live control adapters.